SEGURANÇA CLOUD: IAM, REDES E BOAS PRÁTICAS

Arquitetura Cloud Segura na AWS

Uma aplicação web sem expor seus componentes internos

Pedro Henrique · Emanuel Gondim · Ricardo Silva · Vitor Marques

CENÁRIO

O desafio: migrar sem expor nada

Aplicação com interface web, API, banco de dados e arquivos. Só a entrada pode ser pública.



Defesa em profundidade

Várias camadas independentes



Isolamento

Sub-redes por função, em 2 AZs



Menor privilégio

Só as portas e permissões necessárias



Rastreabilidade

Toda ação registrada e analisada

VISÃO GERAL

Um único ponto de entrada público

Usuário

HTTPS na porta 443

CloudFront + WAF

TLS (ACM), regras OWASP, rate limit

ALB

Só aceita tráfego do CloudFront

ECS Fargate

API em sub-rede privada

RDS

PostgreSQL Multi-AZ, sem IP público

Arquivos no **S3 privado**, acessado só pelo VPC Endpoint. Admins entram por **Client VPN + MFA**.

REDE

VPC em 3 camadas e 2 zonas de disponibilidade

Pública

10.0.1.0/24 · 10.0.2.0/24

ALB e NAT Gateway

Rota: Internet Gateway

Privada: aplicação

10.0.11.0/24 · 10.0.12.0/24

ECS Fargate e endpoints

Saída só via NAT

Privada: dados

10.0.21.0/24 · 10.0.22.0/24

RDS primário e standby

Nenhuma rota para a internet

Se a camada pública for comprometida, não existe rota nem regra que alcance o banco.

SECURITY GROUPS

Cada camada só fala com a próxima

1 · Ingress

sg-alb

Entrada: 443 só do CloudFront

2 · App

sg-app

Entrada: 8080 só do sg-alb

3 · Database

sg-db

Entrada: 5432 só do sg-app

Conexões bloqueadas

Internet → ALB direto

Exige CloudFront e cabeçalho secreto

Internet → API ou banco

Sem IP público e sem rota

SSH e RDP

Nenhuma porta aberta, sem bastion

DADOS

Arquivos, segredos e criptografia

S3 privado

Acesso só pelo VPC Gateway Endpoint

Bucket policy nega qualquer outra origem

Block Public Access e versionamento

Segredos

Secrets Manager com rotação automática

Nada de senha no código ou na imagem

Criptografia

KMS no S3, RDS e logs

TLS em todo o tráfego externo e no banco

O tráfego para o S3 nunca passa pela internet pública.

IAM

Identidade e acesso: menor privilégio

Pessoas

IAM Identity Center com MFA obrigatório

Grupos: Administradores, Desenvolvedores, Auditoria

Credenciais temporárias, sem access key fixa

Serviços

Task Role só com S3 do app, segredo do banco e chave KMS

Task Execution Role só para ECR e logs

Acesso administrativo

AWS Client VPN com login federado e MFA

Sem bastion e sem SSH

Logs de cada conexão

MONITORAMENTO

Tudo registrado, tudo analisado

CloudTrail

Quem fez qual ação na conta

VPC Flow Logs

Conexões aceitas e rejeitadas

WAF e ALB

Ataques e picos de requisições

GuardDuty

Comportamento malicioso

AWS Config

Mudança para estado inseguro

Security Hub

Painel único dos achados

Alarmes no CloudWatch avisam a equipe via SNS. Logs ficam em S3 com **Object Lock**: nem um invasor apaga as evidências.

CONCLUSÃO

Como a arquitetura reduz os riscos

Exposição de dados

Banco e arquivos privados, tudo criptografado

Acesso não autorizado

Entrada única, SGs encadeados, MFA

Ataques e movimento lateral

WAF, Shield e 3 camadas de rede

Indisponibilidade

2 AZs, RDS Multi-AZ, auto scaling

Obrigado! Perguntas?